Cyber Threats

Learning Goals

Learn basic properties of security and privacy

Get and overview of cyber threats

Break cyber attack lifecycle into different steps

Differentiate classes of cyber threats

Basic Security Properties

Confidentiality

Keep information secret, e.g., passwords

- Give read access only to those who need to know

Approach: access control, sealing, encryption

Integrity

Keep information correct, e.g., my account balance, the result of a vote

- Prevent modification of data
- Detect modification

Approach: add a hash, a MAC or a signature, make data public

Availability

Keep information available/systems running, e.g., my photos, my web shop

- Protect against denial of service

Approach: make copies, duplicate/distribute systems, prevent intrusions

Authenticity

Demonstrate the authenticity of information, e.g. gift card, website of a bank

- Prevent fake information
- Detect modification/tampering

Approach: add a keyed hash (MAC) or a signature

Authenticity is also called integrity of origin

Non Repudiation

Prevent denial of a statement (e.g. payment order)

- Proof of actions/statement

Approach: add a signature as proof of origin

Basic Privacy Properties

Confidentiality

Keep information of the **data subject** (i.e. the person mentioned in the data) secret (e.g. age, opinions, health)

- Give (limited) access only to those who need to know

Approach: access control, encryption, absence of data

Anonymity

Prevent a link between data and a subject (e.g. postal address and age to person)

- Reduce/modify information until no correlation is possible

Approach: k-anonymity, different privacy

Absence of Information

Prevent revealing information

- query a db without the db seeing what you are querying
- train a machine learning model without revealing the training data
- confirm a vote, without knowing what the vote is

Do not request, or delete information that is no longer needed

European Approach: store as little data as possible

Approach: homomorphic encryption, private information retrieval, zero knowledge proofs

Differences Between Security and Privacy

Security protects the data of **data owners** (e.g. company) against attacks

Privacy protects the **data subject** against abuse

It is in a company's interest to have good security

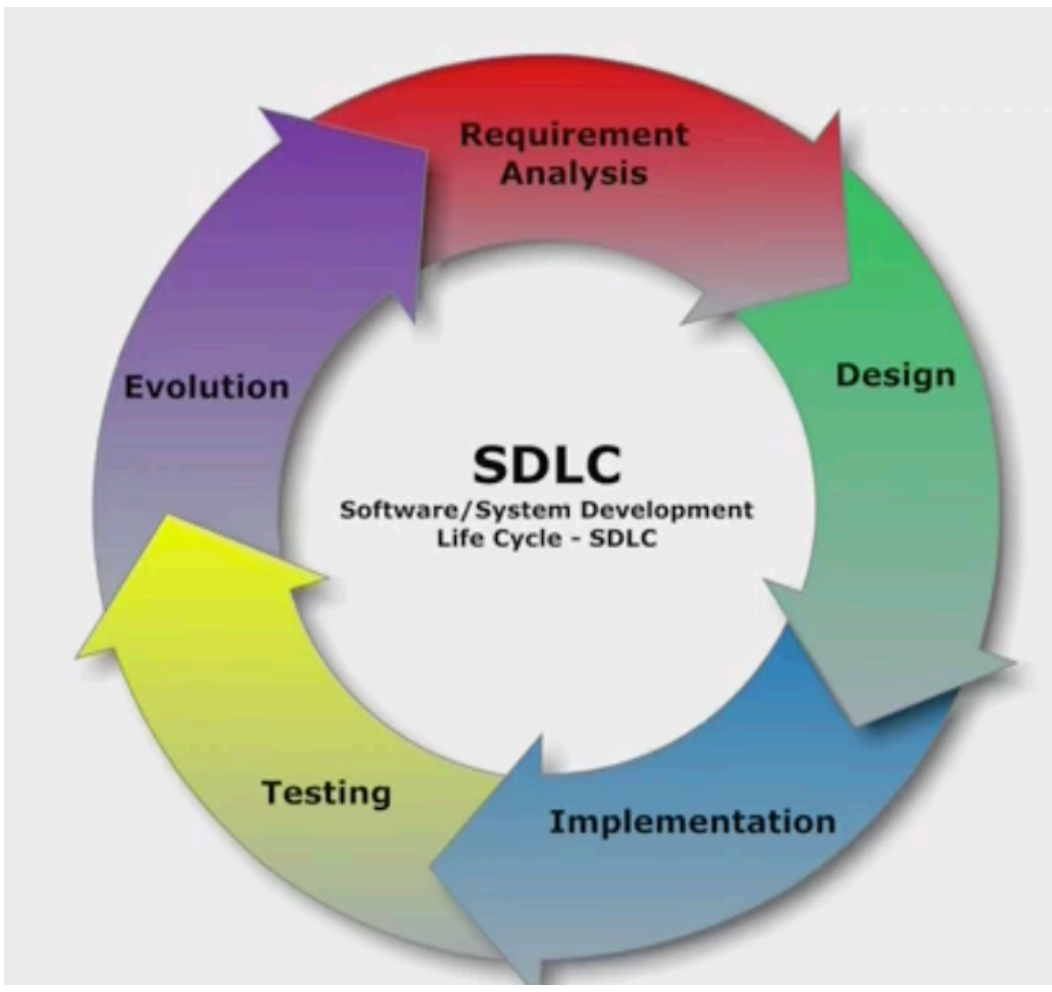
Protecting the privacy of its customers does not always have a benefit for a data owner: some make money by abusing privacy (Facebook?)

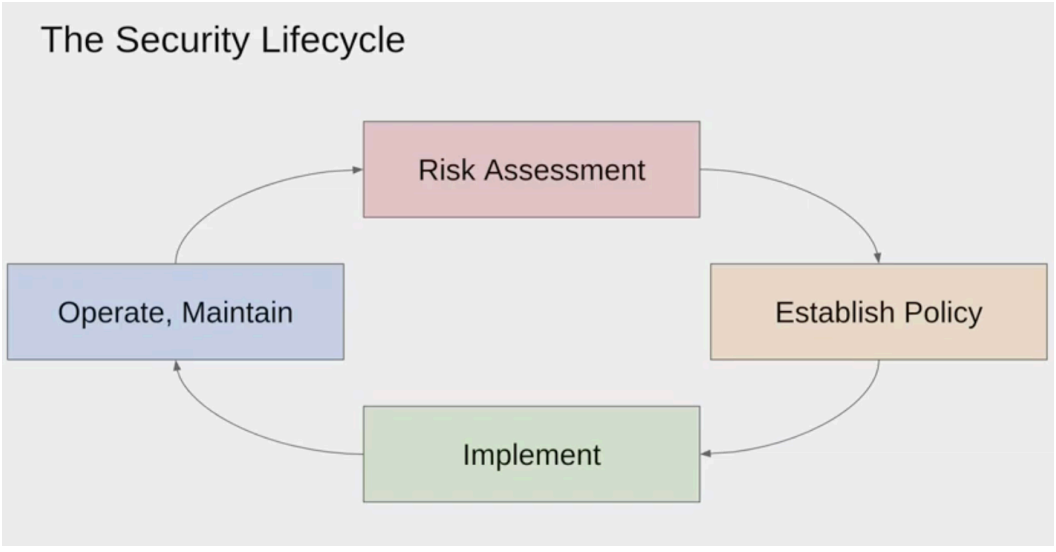
We need strong laws to force companies to protect user privacy (e.g. GDPR)
Privacy by design: choose a design that achieves its goal while minimizing the threats to privacy, e.g. SwissCovid app

The Software/System Development Lifecycle

Happens in phases...

- Requirement Analysis
- Design
- Implementation
- Testing
- Evolution
- Repeat





Risk Assessment

Identify assets, their threats and vulnerabilities

Analyze the corresponding risk (impact, probability)

Evaluate which risks are acceptable, which must be treated

Establish Policy

What is, and what is not allowed, e.g. personal data must be protected

Makes use of security mechanisms

- Personal data must be encrypted
- Require anti-virus software/endpoint scanning
- Require two-factor authentication
- Establish backup strategy
- Name a data protection officer

Implementation

Specify, design, and implement security policies

Clearly define and lay out policies with the goal of making them enforceable

Operation, Maintain

Maintain security

Enforce/apply properties in practice

Case Study: Liblzma Backdoor (Lessons Learnt)

Be aware of supply chain security

- Third party library can cause system REC

Testing can discover vulnerabilities

- OSS-Fuzz was modified to hide this bug

Update the software for bug fix

- Update after security update is released

OSS developers are overwhelmed

- They're unpaid volunteers

Cyber Threats

📖 Definition (ISO 27000):

"Potential cause of an unwanted incident, which can result in harm to a system or organization"

📖 Definition (NIST FIPS 200):
"Any circumstance or event with the potential to adversely impact organizational operations (including mission, functions, image, or reputation), organizational assets, or individuals through an information system via unauthorized access, destruction, disclosure, modification of information, and/or denial of service. Also, the potential for a threat-source to successfully exploit a particular information system vulnerability"

Types of Threats

- **Environment threats**: fire, water, pollution, earthquakes, cosmic radiation, war-like events, riots
- **Loss of essential** services: power, cooling, communication
- **Technical failures**: disk failure
- **Cyber**: malicious software, denial of service, social engineering, software vulnerabilities/exploits

This lecture focuses on **cyber threats**!

Motivation for Attacks

Originally: curiosity, fun, fame

Now:

- Profit: small crime, organized crime, industrial espionage
- Beliefs (hacktivism): e.g. Anonymous, Lulzec, Guardians of Peace
- National Security: police forces, national intelligence

Profit (dark side):

- getting clicks on spam or ads
- resale of accounts, credit card numbers
- rental of hacked PCs (botnets)
- demande of ransom (e.g. to decrypt files)

Profit (gray side)

- sell the vulnerabilities you discover to some broker

Cyber Attack Lifecycle

Phase 0: Preparation

- Define target, from broad (everyone) to focused (individual)
- Find and organize accomplices
- Build and/or acquire tools
- Research target (infra & people)
- Test for detection

Phase 1: Gain Access

- Deployment (social engineering, exploits, etc.)
- Initial intrusion
- Outbound connection established

Phase 2: Maintain Access

- Strengthen foothold: persistence, lateral movement
- Expand access, obtain credentials

Phase 3: Complete mission

- Exfiltrate data
- Manipulate, sabotage data

Phase 4: Cover tracks

- Delete log files

Commodity Threats

Non-targeted (”shotgun” approach)

Usually non-stealthy and fully automated

Goal is often short-term financial gains

Often considered low risk to attackers

Possible starting point for more sophisticated attacks

Forms:

- Malware infected spam
- Extorsion spam
- Malicious ads
- Computer worm

Malware spam

Sent broadly to many people (i.e., not targeted)

Crude customization (e.g., Swiss Post, LinkedIn, ...)

Attachment contains well-known malware

Campaigns are life hours to days

Extortion

Sent broadly to many people (i.e., not targeted)

Relies on leaked information, e.g., password lists

Convinces user of “hack”

Hacktivism

Several meanings such as:

- politically motivated hacking
- variant of (anarchic) civil disobedience

Good options

- create software to encrypt communications
- create tools to bypass censorship

Cyber threats

- Website defacement (e.g. Anonymous, Lulzsec)
- Anonymous publication of confidential data
- Distributed denial of service (DDoS)

Examples:

- Panama Papers (2016)
- Epik data breach (2021)
- OpRussia (2022)

Advanced Persistent Threat (APT)

Advanced

Targeted, multi-step attack, often uses specialized tools, often starts with spear-phishing (targeted phishing attack)

Persistent

‘Low and slow’ approach, prioritize long-term over short-term goals, continuous monitoring and interaction (attacks are know to have lasted 5 years)

Threat

Human coordinated attack; attackers are skilled, motivated and well-funded (e.g. industrial espionage). No ‘fire and forget’ approach, not fully automated

Classes of Malware

- Malware = MALicious softWare
- Virus: spreads by infecting other files
- Worm: spreads automatically to other systems
- Trojan: malware hidden in useful software
- Rootkit: hides presents of malware on computer
- Ransomware: encrypts files and requests payment for decryption
- Nation state malware: malware developed by a nation-state

Botnets: Computer for Hire

Mirai Botnet consists of 150k IoT cameras

Used to sell computer for, e.g., distributed denial of service attacks (DDoS)

Denial of service overwhelms target computer with large amount of requests

Social engineering

“Hacking humans”: use psychological tricks to manipulate another human

Social engineers use phishing, pretexting, baiting, or tailgating

May target employees, customers, or vendors

Intent to obtain sensitive information, gain unauthorized access, commit fraud

Prevented by awareness, training, and robust security measures

Vulnerabilities and Exploits

Vulnerability: weakness in the logic, software or hardware of a system (bugs)

Proof of Concept (PoC): demonstrate the existence of vulnerability

Exploit: demonstrate that attacker can do harm via the vulnerability

Vulnerabilities can be fixed by patching a system

Typical Software Vulnerabilities

- Buffer / heap / stack overflows: violating memory safery
- Unvalidated input, including SQL injection: mixing code and data

- Race conditions: changes of the order of events cause a change in behavior
- Insecure file operations: incorrect assumptions about ownership, location or attributes
- Side-channel leakage: leaking information via time, power, sounds, etc.
- Weakness in the implementation of access control: authentication and authorization flaws.